

Setnayan Privacy Manual

DRAFT — for DPO (Indalecio Sacdalan Casasola II) + PH counsel finalization and NPC filing; not yet adopted.

Date drafted: **2026-07-05**

Document ID: `NPC_Compliance/01_Privacy_Manual_DRAFT_2026-07-05.md`

Governing law: Republic Act No. 10173 (Data Privacy Act of 2012), its Implementing Rules and Regulations (IRR), and issuances of the National Privacy Commission (NPC).

This Privacy Manual is the flagship governance document of the Personal Information Controller. It states how the organization collects, uses, stores, discloses, and disposes of personal data; how it upholds the rights of data subjects; and how it manages security, breaches, and cross-border transfers. It is intended to be kept on file and presented to the NPC on request.

1. Introduction, Purpose & Scope

1.1 The Personal Information Controller (PIC)

Field	Value
Legal entity	SETNAYAN SOFTWARE DEVELOPMENT SERVICE — a sole proprietorship of Indalecio Sacdalan Casasola II
DTI Business Name Registration	No. 8297508 (national scope; valid 25 Jun 2026 – 25 Jun 2031)
Brand	Setnayan
Domains / platform	<code>setnayan.com</code> · <code>setnayan.ph</code>
Nature of business	Philippines-first life-events (weddings-first) planning platform serving three roles — customers (couples/organizers), vendors, and guests
Registered address / principal place of business	[TO CONFIRM]
Number of employees / personnel with access to personal data	[TO CONFIRM]
Approximate number of data subjects	[TO CONFIRM]
NPC registration number (PIC/DPO registration)	[TO CONFIRM]

1.2 Purpose

This Manual:

- Documents the PIC's personal data processing activities and the safeguards applied to them.
- Serves as the reference for all personnel who process personal data on the PIC's behalf.
- Demonstrates the PIC's accountability and compliance posture to the NPC, to data subjects, and to partners.
- Operationalizes the binding **Setnayan Privacy & Security Policy** (`01_Contracts/Setnayan_Privacy_and_Security_Policy.md`), which every account holder accepts at registration.

1.3 Scope

This Manual applies to **all personal data** processed by the PIC across all systems, personnel, contractors, and sub-processors, in every format (electronic and, where applicable, physical). It covers the personal data of **customers, vendors, and guests**, and the internal personnel data the PIC processes as an employer/engager [TO CONFIRM headcount].

1.4 Commitment to RA 10173

The PIC commits to upholding the three data privacy principles — **transparency, legitimate purpose, and proportionality** — and to protecting the rights of every data subject. The platform is built on a **privacy-by-design + compliance-by-default** posture: privacy safeguards are engineered into the systems (row-level access control, encryption, per-event scoping) rather than bolted on. The organization's person-graph features are **adults-only**; processing of minors' data and legacy/post-mortem data is a future, counsel-first phase and is **not undertaken now**.

2. Definitions

Terms used in this Manual carry the meanings assigned by RA 10173 and its IRR:

Term	Meaning
Personal Information (PI)	Any information from which the identity of an individual is apparent or can reasonably and directly be ascertained, or when put together with other information would directly and certainly identify an individual.
Sensitive Personal Information (SPI)	PI about an individual's race, ethnic origin, marital status, age, colour, religious/philosophical/political affiliations; health, education, genetic or sexual life; any proceeding for any offence; government-issued identifiers (SSS, TIN, etc.); and information specifically established by law as classified.
Privileged Information	Any and all forms of data which, under the Rules of Court and other pertinent laws, constitute privileged communication.
Personal Information Controller (PIC)	A person or organization who controls the collection, holding, processing, or use of personal information — here, SETNAYAN SOFTWARE DEVELOPMENT SERVICE.
Personal Information Processor (PIP)	Any natural or juridical person to whom a PIC may outsource or instruct the processing of personal data (the PIC's sub-processors — see § 8).
Data Subject	The individual whose personal information is processed — Setnayan's customers, vendors, and guests.
Processing	Any operation performed upon personal data — collection, recording, organization, storage, updating, retrieval, consultation, use, consolidation, blocking, erasure, or destruction.
Consent	Any freely given, specific, informed indication of will by which the data subject agrees to the processing of personal data about them.
Data Protection Officer (DPO)	The individual designated by the PIC to be accountable for compliance with RA 10173.

Personal Data Breach	A breach of security leading to the accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or access to, personal data.
-----------------------------	--

3. Governance & Organizational Structure

3.1 Data Protection Officer (DPO)

Field	Value
Designated DPO	Indalecio Sacdalan Casasola II
DPO contact	iscasasolaii@gmail.com
NPC DPO registration	[TO CONFIRM]

The DPO is the organization's accountable officer for data privacy and the single point of contact for data subjects and for the NPC. The DPO's responsibilities include:

- Monitoring and ensuring the PIC's compliance with RA 10173, its IRR, NPC issuances, and this Manual.
- Serving as the contact point for data subject requests and complaints (access, rectification, erasure, objection, portability, and breach inquiries).
- Overseeing the conduct of Data Privacy Impact Assessments (DPIAs — see § 10) and maintaining the DPIA register.
- Leading the security incident and breach response process (see § 9), including NPC and data-subject notification.
- Cultivating a privacy-aware culture through personnel training and periodic review of policies.
- Reviewing and advising on sub-processor engagements and cross-border transfers.

3.2 Security Measures — Overview

The PIC maintains organizational, physical, and technical security measures proportionate to the nature of the personal data processed and the risks involved. The measures below summarize the controls already in place per the binding Privacy & Security Policy.

3.2.1 Organizational measures

- **Binding policy acceptance.** Every customer, vendor, and guest accepts the Privacy & Security Policy at registration; acceptance is logged with timestamp, IP, and user-agent in a `policy_acceptances` record per user.
- **Role-based responsibility.** Internal (admin) access is gated to granular roles; each role can only reach the surfaces it is permitted.
- **Two-admin approval** for high-impact actions — role provisioning, brand-configuration changes, refunds above ₱10,000, and unlimited-use grants above ₱10,000 retail value.
- **Confidentiality obligations** on personnel and contractors [TO CONFIRM: signed NDAs / conduct policy on file].
- **Privacy training** for personnel who process personal data [TO CONFIRM: cadence].

3.2.2 Physical measures

- **No self-hosted data centre.** The PIC does not operate physical servers; personal data resides with managed cloud processors (Supabase, Cloudflare) under their physical-security controls and data-processing agreements.
- Access to workstations and administrative credentials is restricted to authorized personnel [TO CONFIRM: device/endpoint policy].

3.2.3 Technical measures

Control	Implementation
Access control (deny-by-default)	Row-Level Security (RLS) on the Postgres database — every query is gated so no client can read another user's row. Deny-by-default is the baseline; access is granted only by explicit policy.
Encryption in transit	TLS 1.3 on all external connections and WebSocket channels; HSTS enabled in production; mixed content blocked.
Encryption at rest	AES-256 on the database and object storage; keys managed by the cloud providers' key-management services. Face vectors stored in a per-event encrypted vector index.
Authentication	Email + password (bcrypt-hashed, never plaintext), or mobile + OTP, or Google/Apple SSO; TOTP two-factor available for customers/vendors and mandatory for all admin roles .
Session management	30-day inactivity expiry; refresh tokens stored httpOnly; single sign-out across all devices.
Short-lived media access	Object storage is private; access is via short-lived signed URLs (5 minutes for sensitive media). No public reads.
Application hardening	Input validation at every entry point; parameterized queries (no SQL injection); output escaping + CSP (no XSS); CSRF tokens on state-changing requests; rate limiting on auth endpoints.
Audit logs	Every admin action is logged append-only (no UPDATE permission) with timestamp, actor, action type, target entity, before/after state, and rationale.
Backups	Daily encrypted database backups retained 30 days.

4. Data Processing Principles Applied

The PIC applies the three RA 10173 principles to every processing activity:

4.1 Transparency

Data subjects are informed of the nature, purpose, and extent of processing before or at collection. Mechanisms:

- Registration-time acceptance of the Privacy & Security Policy (logged per user).
- A published privacy notice on setnayan.com/privacy and a changelog at setnayan.com/privacy/changeLog; material changes carry 30 days' notice and a re-consent prompt where processing changes.
- The DPO's contact (iscasasolai@gmail.com) is published as the channel for questions and rights requests.

4.2 Legitimate Purpose

Processing is limited to declared, specified, and legitimate purposes and is never incompatible with them. Concrete examples:

- **Service delivery** — providing the planning tools, gallery, RSVP, and vendor-matching a customer contracts for (basis: performance of contract / legitimate interest).
- **Payments** — apply-then-pay reconciliation using **reference data only**; no card, CVV, or full bank-account numbers are stored (basis: performance of contract).
- **Vendor verification** — identity, business-registration, and sanctions screening at onboarding (bases: consent, legitimate interest, compliance with the PH Anti-Money Laundering Act).
- **Face auto-tagging** — matching a guest to their own photos, per-event only, on explicit/implied consent (basis: consent).

4.3 Proportionality

Only data adequate, relevant, and necessary to the declared purpose is processed:

- **Payment data minimization** — reference and receipt data only, never full credentials.
- **Per-event face scoping** — face vectors are generated and used **per event only, never reused across weddings**, and are deleted with the event data. There is **no cross-event face recognition**.
- **Person-graph minimization** — connections require **mutual confirmation**; cross-person visibility is **name-only**; extended relationships are **derived, never stored**; trusted-circle signals are **aggregated/computed** (≥ 5 minimum), **never per-person records**.

5. Data Lifecycle: Collection → Use → Storage → Disclosure → Disposal

5.1 Collection

Personal data collected, by role:

Role	Categories collected
Customer (couple/organizer)	Full name, mobile, email, optional profile photo; event details (date, venue, target pax, role); payment reference/receipt data (no full credentials); in-app behavioral data; uploaded content (photos, invitation customizations); chat messages with vendors/coordinators.
Vendor	Business + identity documents (DTI Business Name Certificate, BIR Form 2303, Mayor's Permit, government ID, bank-account proof, portfolio, client references, live selfie + liveness); service profile; payout account and transaction history; behavioral data; chat messages. Includes SPI (government-issued identifiers).
Guest	Full name, mobile, email, optional profile photo; event linkage and role; RSVP status and table assignment; captured/tagged photos and clips; behavioral data (reels built, reshares).
Face vectors (special category)	Per-event face vectors derived from RSVP profile photo + optional pre-event upload + on-the-day check-in kiosk, used only for auto-tagging within that one event.

5.2 Use

Primary uses: providing contracted services, vendor matching, payment processing, per-event photo auto-tagging, event/payment notifications, and aggregated platform analytics. Secondary uses (anonymized aggregate improvement/ML, marketing samples, promotional communications) require **separate, revocable consent**. Personal data is **never sold**, never used for external targeted advertising, and never shared with government except as required by Philippine law (subpoena/court order).

5.3 Storage, Residency & Retention

System	Location	Content
Database (Postgres)	Supabase — Singapore	PII + transactional data, RLS-gated, AES-256 at rest
Object storage	Cloudflare R2 — APAC region	Photos/videos, per-event encrypted face-vector index, vendor verification documents; private + signed-URL access
Email	Resend	Transactional/notification email delivery

Representative retention windows (full table in the Privacy & Security Policy § 4):

Data type	Retention	Deletion trigger
Customer/vendor account profile	Active	Account deletion + 30-day grace then purge
Customer event data	5 years post-event	Auto-purge at T+5 years (or earlier on request)
Photo/video originals	90 days hot → 5 years cold	5-year hard limit
Face vectors	Per-event lifetime + 5 years	Auto-purge with event data; guest "delete my face data" revokes within the refresh cycle
Vendor verification audit trail / permits	90 days hot → 7 years cold	BIR § 235 + AMLC AML/CTF retention
Chat messages / audit logs	5 years	Aligned with event / tax-legal retention
Anonymized aggregate data	Indefinite (no PII)	Not auto-purged

5.4 Disclosure / Sharing

Disclosure is limited to the sub-processors in § 8, each engaged under a data-processing agreement and used only for the declared purpose. Internal (Setnayan Team) access to event media is read-only, case-scoped to mediation, and never bulk-exported.

5.5 Disposal

Disposal occurs by automated purge at the retention boundary or on a validated deletion request. Account deletion cascades to profile, event memberships, face vectors, individual photos of the subject (subject to event-organizer consent for shared galleries), and chat history — **except** records the PIC must retain for PH tax/legal compliance (e.g., BIR vendor records, payment receipts), which are retained for their statutory period and then destroyed.

6. Data Subject Rights

Every data subject has the following rights under RA 10173. All are exercised by contacting iscasasolaii@gmail.com (and, for several, via in-app settings surfaces).

#	Right	How to exercise / PIC response
1	Right to be informed	Via this Manual, the published privacy notice, and registration-time disclosures.
2	Right to access	Request a copy of personal data held, via iscasasolaii@gmail.com . Response: within 7 business days for non-urgent requests.
3	Right to object	Opt out of specific data uses (e.g., marketing samples, promotional email) via settings or iscasasolaii@gmail.com .
4	Right to rectification	Edit profile in-app; request corrections via iscasasolaii@gmail.com .
5	Right to erasure or blocking	Delete account via the in-app "Delete my account" surface; confirmed within 30 days ; cascade per § 5.5, with statutory-retention exceptions.
6	Right to damages	File a complaint with the NPC for violations; the PIC cooperates with any NPC proceeding.
7	Right to data portability	Export event data, photos, and chat history in a machine-readable format, via iscasasolaii@gmail.com or in-app export.
8	Right to be notified	Notification of any breach affecting the subject's data, per § 9.

Person-graph specific rights: a data subject may decline connection requests, remove confirmed connections, hide individual life-story items per-person (without affecting the host's gallery), and opt out of an event's story entirely; deletion cascades to their connections and story-item references.

7. Consent Management

- **Registration consent.** Acceptance of the Privacy & Security Policy is captured and logged (timestamp + IP + user-agent) at account creation.
- **Face detection.** Guests consent to face auto-tagging by uploading an RSVP profile photo for that purpose (implied consent) and can withdraw at any time via a "Photo Consent" toggle; withdrawal triggers face-blur in captures and revocation of face data. Face processing is **per-event only**.
- **Vendor verification consent.** Vendors give explicit, itemized consent at registration for DTI lookup, third-party ID/liveness verification, portfolio reverse-image search, reference calls, and AMLC sanctions screening.
- **Marketing samples.** Use of a customer's renders/captures as marketing samples requires a **separate written opt-in**, revocable at any time; existing materials are removed within 90 days of revocation.

- **Person graph.** Connections require **mutual confirmation** (no one-sided edges); life-story items rely on existing event photo-consent and are individually hide-able/opt-out-able; trusted-circle recommendations are aggregate-only.
- **Withdrawal.** Consent may be withdrawn at any time through settings or iscasasolaii@gmail.com, without affecting the lawfulness of prior processing.
- **Material changes** to processing carry 30 days' advance notice and a re-consent prompt at next login where the change affects data use.

8. Data Sharing, Sub-Processors (PIPs) & Cross-Border Transfers

8.1 Hosting & cross-border disclosure

The PIC's primary infrastructure is hosted **outside the Philippines**: the database in **Singapore** (Supabase) and object storage in the **APAC region** (Cloudflare R2). Routine application operations therefore involve **cross-border processing**. All such transfers are encrypted in transit (TLS 1.3), governed by the providers' data-processing agreements, and remain subject to NPC oversight; the PIC remains accountable for personal data transferred to any processor.

8.2 Sub-processors (Personal Information Processors)

Sub-processor	Jurisdiction	Data shared	Purpose
Supabase	Singapore	PII + transactional data	Managed database hosting
Cloudflare (R2)	APAC region	Media, face-vector index, vendor documents	Object storage / CDN
Resend	[TO CONFIRM jurisdiction]	Recipient email + message content	Transactional email delivery
Persona / Veriff / Onfido	US	Vendor government-ID image + selfie + liveness	Vendor identity verification
AMLC API / ComplyAdvantage	PH / UK	Vendor business + owner name	Sanctions / PEP screening (PH AMLA compliance)
DTI Database	PH	Vendor DTI certificate number	Business-registration validation
Anthropic / OpenAI	US	Vendor contract text (AI features only)	Contract analysis and AI features; the specific model is not named to users . Configured for zero-retention where available.
Suno	[TO CONFIRM jurisdiction]	No personal data	Music generation (owned AI catalogue)

All non-ASEAN sub-processors are bound by Standard Contractual Clauses (SCCs) or equivalent enforceable data-processing agreements. AI/verification/screening calls are batch/inference-only with no ongoing storage at the sub-processor where so configured. [TO CONFIRM: executed DPA on file for each active processor.]

9. Security Incident & Personal Data Breach Management

The PIC maintains a documented incident-response and breach-management process. Summary posture:

- **Detection & assessment.** Incidents are assessed by the DPO and response team to determine whether a **personal data breach** has occurred and its severity.
- **NPC notification.** Where the breach is notifiable, the NPC is notified **within 72 hours** of knowledge/confirmation, consistent with RA 10173 and NPC Circular 16-03.
- **Data-subject notification.** Affected data subjects are notified **within 72 hours** (in-app + email) of what data was involved, when, remedial actions taken, and recommended protective steps.
- **Public disclosure.** A breach summary is posted on setnayan.com/security within 7 days where appropriate.
- **DPO channel.** Breach inquiries go to iscasasolaii@gmail.com; a hotline is used for high-severity incidents.
- **Records.** All incidents and responses are documented for the mandatory breach report and NPC review.

The full procedure — response team, severity matrix, containment/eradication/recovery steps, notification templates, and the breach register — is maintained in the **Data Breach Management Policy**:
[NPC_Compliance/04_Data_Breach_Management_Policy_DRAFT_2026-07-05.md](#).

10. Data Privacy Impact Assessments (DPIA)

The PIC conducts a **DPIA** before undertaking any processing that is likely to pose a risk to the rights and freedoms of data subjects — in particular new features involving sensitive or high-volume personal data (e.g., face vectors, the person graph, vendor identity verification, and any future minors/legacy processing). Each DPIA identifies data flows, risks, and mitigations, and is reviewed by the DPO before the processing goes live.

The DPIA methodology and the register of completed/pending assessments are maintained in:
[NPC_Compliance/05_DPIA_Register_DRAFT_2026-07-05.md](#).

Minors' data and legacy/post-mortem processing are **not undertaken now**; when contemplated, each will be **counsel-first** and gated on a dedicated DPIA and guardian-consent/post-mortem mechanics.

11. Inquiries, Complaints & NPC Contact

- **Data subject inquiries and complaints** are directed to the DPO at iscasasolaii@gmail.com. The DPO acknowledges and responds within the timelines in § 6, coordinates rectification/erasure/objection, and maintains a record of complaints and their resolution.
- **Escalation to the NPC.** A data subject who is not satisfied may lodge a complaint with the **National Privacy Commission**:

National Privacy Commission
5th Floor, Philippine International Convention Center (PICC) Complex, Vicente Sotto St., Pasay City, Metro Manila 1307
Email: info@privacy.gov.ph · Website: privacy.gov.ph
[TO CONFIRM current NPC address/contact at time of filing]

12. Review, Version Control & Effectivity

- **Ownership.** This Manual is owned by the DPO (Indalecio Sacdalan Casasola II) and approved by the PIC (Indalecio Sacdalan Casasola II).

- **Review cadence.** Reviewed at least **annually**, and additionally upon any material change to systems, sub-processors, or applicable law/NPC issuances.
- **Change control.** Material changes to processing are communicated to data subjects per § 7 and § 11 of the Privacy & Security Policy (30 days' notice; re-consent where required; public changelog).
- **Effectivity.** This document is a **DRAFT** and takes effect only upon adoption and sign-off by the DPO/counsel and, where required, NPC filing.

Version	Date	Author	Status
0.1 (DRAFT)	2026-07-05	Prepared for DPO/counsel review	Not yet adopted
Adopted	[TO CONFIRM]	Indalecio Sacdalan Casasola II (DPO)	[TO CONFIRM]

Approval blocks (to be completed on adoption):

- PIC / Owner: Indalecio Sacdalan Casasola II — Signature: __ Date: ____
- DPO: Indalecio Sacdalan Casasola II — Signature: __ Date: ____

Footnote. This document was drafted to a compliant RA 10173 baseline **ahead of counsel** to accelerate finalization. It is **not a substitute for legal review**. The designated DPO (Indalecio Sacdalan Casasola II) + PH counsel must verify every [TO CONFIRM] fact, confirm alignment with the current NPC issuances, and formally adopt this Manual before it is relied upon or filed.